INSPECCO × KRIPTARIUM

Safety 4.0 Bootcamp

Laboratuvar Föyleri — PaketPro 3000 Sürümü · Paketleme Makinesi

Tüm laboratuvarlar deck'in işlenmiş örnek makinesi PaketPro 3000'e uyarlanmıştır: sıcak çene + kesme bıçağı · ışık perdesi · 16 varlık + 5 dış bağlantı · internete açık uzak bakım modülü.

LAB 1 · Safety Architecture	Çıktı: Safety Function Map
LAB 2 · IEC 62443 Mini Workshop	Çıktı: Zone / Conduit Diagram
LAB 3 · Threat & Risk + Risk Matrix	Çıktı: Risk Register
LAB 4 · Secure Remote Access	Çıktı: Secure Architecture
LAB 5 · SBOM / CVE / Patch	Çıktı: Vulnerability Decision
LAB 6 · CRA Incident Simulation	Çıktı: Incident Workflow
LAB 7 · AI Safety Challenge	Çıktı: AI Fail-Safe Decision

Bu föyler bir eğitim çıktısıdır; resmî denetim, uygunluk değerlendirmesi veya belgelendirme değildir ve CE/mevzuat uygunluğu garantisi vermez. Doldurduğunuz föyler gün sonunda Machine Starter Pack'inizi oluşturur ve Safety 4.0 Workspace'te yaşamaya devam eder.

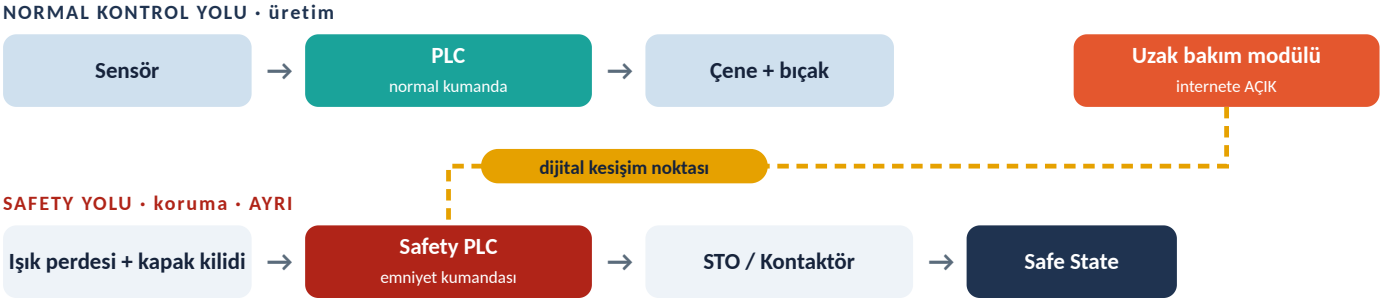
LABORATUVAR 1 · PAKETPRO 3000 · Paketleme Makinesi

Safety Architecture

Çıktı: Safety Function Map

Ad Soyad Beşir Can Barutçu | Grup | Tarih 23.10.2026

PaketPro bağlamı: Sıcak yapıştırma çenesi ve film kesme bıçağı el/parmak için ciddi tehlikedir; koruma **ışık perdesi + kapak kilidi → Safety PLC → STO** zinciridir. Ve bu makinenin **internete açık bir uzak bakım modülü** vardır — sorular oraya gidecek.



Görev — sırayla cevaplayın

1 Bu makinede tehlike nedir? İnsan neyden zarar görür?

Makine: KANTEC Gradius (robotik tepsi besleme). Tehlike: hızlı hareket eden endüstriyel robot kolu ve konveyörler. Operatör tepsi yüklerken veya sıkışmayı açarken eli/kolu robota ya da konveyör sıkışma noktasına girer: ezilme, çarpma, kesik.

2 Safety function (emniyet fonksiyonu) hangisidir?

SF3 giriş/çıkış koruması: ışık perdesi kesilince (muting sadece tepsiler için) robot ve konveyörler durur, STO. Ek olarak SF1 E-stop, SF2 kapı kilidi, SF4 robot zone/hız limiti, SF5 reset (otomatik yeniden başlama yok).

3 Safety-related control system nerede? Şemada işaretleyin.

Alttaki ayrı SAFETY yolu: ışık perdesi + kapı kilidi + E-stop (giriş) → Safety PLC + robot safety kontrolcüsü (mantık) → STO / kontaktör (çıkış) → Safe State. Hat PLC'si, HMI, IPC, vision PC ve uzak servis erişimi bu sistemin parçası değildir.

4 Normal PLC ile Safety PLC farkı nedir?

Normal (hat) PLC: üretimi yönetir (hız, tepsi sırası), tek kanallı, insanı korumak için tasarlanmamıştır. Safety PLC: sertifikalı (PL/SIL), iki kanallı, sürekli kendini test eder; hata görürse makineyi safe state'e alır, sadece emniyet işini yapar.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr/SIL, emniyet fonksiyonunun riske göre ne kadar güvenilir olması gerektiğini söyler. Gradius: S2 ciddi yaralanma, F2 operatör sık müdahale eder, P2 robot hızlı, kaçmak zor → PLr d (en kötü durumda e). Fonksiyon bozulursa sonuç doğrudan yaralanmadır.

6 Safe state (güvenli durum) nedir?

Robot ve tüm konveyörler durmuş, motor torku kesilmiş (STO), hücre kapısı duruşa kadar kilitli. Makine kendi kendine yeniden başlamaz; reset sadece hücre dışından, bilinçli olarak yapılır.

7 Safety function hangi dijital bağımlılıklara sahip?

Safety PLC programı ve konfigürasyonu (ışık perdesi muting süresi, tepki süresi, kapı kilidi gecikmesi) · robot safety kontrolcüsündeki güvenli zone ve hız limiti ayarları · sürücülerin STO parametreleri ve firmware'i · safety haberleşmesi (ör. PROFIsafe) · mühendislik yazılımı ve Safety PLC şifresi · hat PLC'sinden gelen reset/mod sinyalleri.

8 Siber müdahale hangi noktadan bu fonksiyonu bozar?

Şemadaki dijital kesişim noktasından: saldırgan KANTEC'in uzak servis erişimine (C6) veya servis laptop'u/USB'ye (C8) girer → IPC (Z2) → hat PLC'si (Z4) → Safety PLC (Z5). Burada ör. muting süresini 0,5 sn'den 8 sn'ye çıkarır veya robot güvenli zone'unu genişletir; HMI eski değeri gösterir. Işık perdesi kesilse de robot durmaz → operatörün eli robota ulaşır.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur.

LABORATUVAR 2 · PAKETPRO 3000 · Paketleme Makinesi

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad Beşir Can Barutçu | Grup | Tarih 23.10.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Görev A — varlıkları bölgelere ayırın

Varlık listesi

Üretim PLC · **Emniyet PLC'si** · HMI (port 80 web arayüzü!) · motor sürücüleri · **internete açık uzak bakım modülü** · bulut telemetri · Wi-Fi AP (parolası kartonda) · 2 kilitsiz USB · "admin/admin" servis hesabı

1. Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.

Gradius için 7 zone: Z0 Kurumsal IT (müşteri: ERP, MES, ofis) – kapsam dışı · Z1 DMZ: jump server, IoT/veri broker, patch ve yedek sunucusu (SL-T 2) · Z2 Supervisory: hat HMI, endüstriyel PC/reçeteler (SL-T 2) · Z3 Vision/AI: kameralar, vision PC, tutma noktası modeli (SL-T 2) · Z4 Kontrol: hat PLC'si, robot kontrolcüsü, servo sürücüler, konveyör VFD'leri, checkweigher (SL-T 2) · Z5 Safety: Safety PLC, E-stop, kapı kilitleri, ışık perdeleri, robot safety, STO (SL-T 3) · Z6 Harici: KANTEC uzak servis, IoT cloud (güvenilmez). Zone'a girmeyenler: USB portları ve servis laptop'u fiziksel conduit (C8); paylaşılan servis hesabı varlık değil zafiyettir, silinir.

2. Açık uzak bakım modülü hangi bölgeye düşüyor — ve orada KALABİLİR Mİ? Neden?

Gradius'ta karşılığı KANTEC'in uzak servis erişimi. Varsayım: bugün internetten doğrudan IPC/PLC ağına bağlanıyor, yani fiilen Z2/Z4 içinde. KALAMAZ: internetteki biri hat PLC'sine, oradan Safety PLC'ye ulaşabilir. Z1 DMZ'ye taşınmalı; sadece VPN + MFA + jump server ile, varsayılan kapalı, loglanarak erişilmeli ve Z5'e asla ulaşmamalı.

3. Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

C1 Z0↔Z1: firewall, varsayılan reddet, doğrudan IT-OT yolu yok · C6 Z6↔Z1: VPN, MFA, kişisel hesap, varsayılan kapalı, log · C7 Z1→Z6: IoT telemetri sadece dışarı, TLS + cihaz sertifikası · C2 Z1↔Z2: firewall, sertifika, oturum kaydı · C3 Z2↔Z4: rol tabanlı yazma, HMI/IPC'de mühendislik aracı yok · C4 Z3→Z4: tek yön koordinat, robot kontrolcüsünde makullük limiti · C5 Z5→Z4: sadece safety durum okuma, ağdan yazma yok, CRC izlenir · C8 USB/laptop: kapalı/kilitli, sadece yönetilen laptop.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	Jump server: makineye doğrudan bağlantı yok, tek kontrollü giriş (Z1).
Tünel?	Açık / VPN	VPN: trafik şifreli, IPC/PLC internete açık değil.
Kimlik?	Parola / MFA	MFA: çalınan KANTEC mühendis parolası tek başına yetmez.
Hesap?	Paylaşılan / Kişisel	Kişisel: her işlem bir kişiye bağlı, ortak "servis" hesabı yok.
Kayıt?	Yok / Tam oturum kaydı	Tam oturum kaydı: CRA 24s/72s/14 gün için kanıt.
Zamanlama?	Sürekli açık / Varsayılan kapalı	Varsayılan kapalı: müşteri her oturumu süreli açar.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur.

LABORATUVAR 3 · PAKETPRO 3000 · Paketleme Makinesi

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad Beşir Can Barutçu | Grup | Tarih 23.10.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = L × S × E (her biri 1–3). **Kural:** S=3 ise skor düşük olsa bile senaryo öne alınır — insana zarar görünür kalır.

PaketPro'nun kapıları (ipucu)

İnternete açık uzak bakım modülü · admin/admin hesabı · port 80 HMI · Wi-Fi (karton parola) · 2 kilitsiz USB · bulut telemetri — *fiziksel sonuç adayları: çene/bıçakta el-parmak yaralanması, sıkışma.*

Görev — üç senaryo kurun ve puanlayın

Senaryo (kim→kapı→zincir→fiziksel sonuç)	L	S	E	Skor	Öncelik
Hedefli saldırgan → KANTEC uzak servis erişimi (sürekli açık, ortak hesap, MFA yok) → IPC → hat PLC'si → Safety PLC'de SF3 ışık perdesi muting süresini uzatır → operatör sıkışmayı açarken robot durmaz: ezilme	2	3	3	18	Kritik
İçeriden yetkisiz kişi (daha çok üretim isteyen operatör) → paylaşılan HMI parolası (fabrika ağı) → bakım modunda kapı kilidini köprüler → kapı açıkken konveyör/robot çalışır → el konveyör sıkışma noktasında kalır	2	3	2	12	Yüksek
Tedarik zinciri → sahte "Gradius v2.3" güncellemesi USB ile servis laptop'undan (C8) → robot kontrolcüsünün güvenli zone ayarı değişir → robot izinli alandan çıkar, bakım yapan teknisyene çarpar	1	3	1	3	Düşük → S=3, öne alınır

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

1. En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?

   Senaryo 1: kapı sadece ortak servis hesabıyla korunuyor (L=2), robotta ezilme ciddi yaralanma (S=3) ve uzak servis yolu internete sürekli açık (E=3). Puan gerekçeleri: S2 → paylaşılan HMI parolası zayıf (L=2), el sıkışması ciddi (S=3), HMI fabrika ağından erişilir (E=2). S3 → önce tedarikçi güncelleme kanalı ele geçirilmeli (L=1), çarpma ciddi (S=3), USB ile makinede yapılır (E=1).

2. S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?

   Evet, Senaryo 3 (skor 3). Risk register'da "S=3" bayrağıyla işaretlenir ve skoru ne olursa olsun listenin üstünde kalır. Önlemler: sadece imzalı firmware, SBOM kontrolü, değişiklik kaydı; her güncellemeden sonra robot safety konfigürasyonunun CRC'si karşılaştırılır ve SF4 yeniden test edilir. Altın kural kontrolü: üç zincir de "veri çalındı" ile değil, insanın yaralanmasıyla bitiyor.

Altın kural: Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar?

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur.

LABORATUVAR 4 · PAKETPRO 3000 · Paketleme Makinesi

Secure Remote Access

Çıktı: Secure Architecture

Ad Soyad Beşir Can Barutçu | Grup | Tarih 23.10.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Görev A — mevcut → hedef

MEVCUT (çizin/yazın)

İpucu: uzak bakım modülü bugün internete DOĞRUDAN açık.

Varsayım (KANTEC ile doğrulanacak):
KANTEC mühendisi → internet → uzak masaüstü aracı / panodaki 4G modem (sürekli açık) → doğrudan IPC (Z2).
IPC, hat PLC'si, vision PC ve Safety PLC aynı düz ağda; ayrım yok.
Ortak "servis" hesabı + parola, MFA yok, oturum kaydı yok.
IPC'de mühendislik aracı kurulu → Safety PLC'ye ağdan yazılabilir.

HEDEF (beş ilkeyle yeniden tasarlayın)

KANTEC mühendisi → VPN → MFA → jump server (Z1 DMZ) → IPC veya hat PLC'si (Z2/Z4). Safety PLC'ye (Z5) asla ulaşmaz.
1 Ara nokta: jump server, doğrudan bağlantı yok
2 VPN: şifreli tünel, 4G modem/uzak masaüstü kaldırılır
3 MFA + 4 kişisel hesap: ortak servis hesabı silinir
5 Tam oturum kaydı + varsayılan kapalı: müşteri süreli açar
Ek: varsayılan salt okuma, yazma onaylı; C5 sadece durum okuma.

Görev B — functional safety köprüsü

1 Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?

Hayır, etkilenmemeli. Safety PLC ayrı zone'da (Z5); ağdan sadece durum okunur, yazma kapalıdır (C5). Ayar değişikliği sadece sahada, anahtarlı şalter + şifre ile yapılır; her açılışta CRC karşılaştırılır. Işık perdesi, kapı kilidi ve E-stop doğrudan Safety PLC → STO'ya bağlı. Saldırgan üretimi durdurabilir ama insanı koruyan zinciri değiştiremez.

2 Işık perdesi zincirinin uzak bakım yolundan etkilenmemesi için GEREKSİNİMİ yazın (çözümü değil).

GEREKSİNİM: SF3 ışık perdesi zincirinin (sensör → Safety PLC → STO) çalışması ve parametreleri (muting süresi, tepki süresi) hiçbir uzak bakım veya ağ yolundan değiştirilememeli, köprülenememeli, devre dışı bırakılamamalıdır. Muting sadece fiziksel tepsi sensörleriyle tetiklenmeli. Her değişiklik sahada yetkili kişi, doğrulanmış CRC ve değişiklik kaydı gerektirmeli. Uzak yol ele geçirilse de kesilse de safe state'e ulaşma süresi değişmemelidir.

Tarafsızlık notu: Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 + EP 06** başlığına oturur.